FUNDAMENTALS OF CYBER SECURITY
MODULE 3 — HANDWRITTEN QUESTIONS & ANSWERS

Exam-ready notes covering all topics listed under Module 3 in the uploaded FCSDF Question Bank. Related short topics are grouped where appropriate; original topic wording is retained.

Q1. Explain Cyber Security Safeguards and its types in detail.

Answer:

Cyber Security Safeguards are protective measures used to secure computers, networks, applications and information from unauthorized access, attacks, damage or loss.

Types of safeguards:

1. Administrative safeguards:

These are policies, procedures and management practices.

- Security policies and guidelines.
- Employee awareness and training.
- Risk assessment and security audits.
- Background checks and incident response plans.

2. Technical safeguards:

These use technology to protect systems and data.

- Firewalls to filter network traffic.
- Antivirus and anti-malware software.
- Encryption to protect sensitive data.
- Authentication and access control.
- Intrusion Detection/Prevention Systems (IDS/IPS).

3. Physical safeguards:

These protect buildings, devices and infrastructure.

- CCTV cameras and security guards.
- Biometric or card-based entry.
- Locked server rooms and equipment racks.
- Fire alarms, cooling and power protection.

Other common classifications:

- Preventive: Stop incidents before they occur, e.g. firewall and access control.
- Detective: Identify suspicious activity, e.g. IDS and audit logs.

- Corrective: Fix problems after an incident, e.g. patching and malware removal.
- Recovery: Restore normal operations, e.g. backups and disaster recovery.

Conclusion: A combination of administrative, technical and physical safeguards provides layered protection for an organization.

Q2. Describe Cyber Security Audit Process.

Answer:

A Cyber Security Audit is a systematic examination of an organization's security controls, policies, systems and procedures to identify weaknesses and check whether security requirements are followed.

Steps in the audit process:

1. Planning: Define audit objectives, scope, schedule and resources.
2. Information gathering: Collect security policies, network diagrams, asset lists and system details.
3. Risk assessment: Identify important assets, threats and vulnerabilities.
4. Control evaluation: Examine firewalls, access controls, encryption, backups and security procedures.
5. Testing: Review configurations, logs, patch status and permissions. Authorized technical testing may also be performed.
6. Evidence collection: Record observations, screenshots, documents and test results.
7. Analysis: Compare actual controls with required policies or standards and identify gaps.
8. Reporting: Prepare an audit report with findings, risk levels and recommendations.
9. Follow-up: Verify that corrective actions have been completed.

Simple flow:

Planning → Information Collection → Risk Assessment → Control Testing → Findings → Report → Follow-up

Conclusion: A cyber security audit helps an organization discover security gaps, improve controls and maintain compliance.

Q3. Differentiate between different types of firewalls.

Answer:

A firewall is a hardware or software security system that monitors and controls incoming and outgoing network traffic according to predefined rules.

Types of firewalls:

1. Packet-filtering firewall:
Checks packet information such as source IP, destination IP, port and protocol. It allows or blocks packets based on rules.

2. Stateful inspection firewall:
Tracks active network connections and checks whether packets belong to a valid established connection.

3. Circuit-level gateway:
Checks session establishment and TCP handshakes. It generally does not inspect the actual application data.

4. Application-level gateway / Proxy firewall:
Works as an intermediary between the user and a service. It can inspect application-layer traffic such as HTTP.

5. Next-Generation Firewall (NGFW):
Combines traditional firewall functions with features such as deep packet inspection, application awareness and intrusion prevention.

6. Host-based firewall:
Installed on an individual computer or server to control traffic entering or leaving that device.

7. Network-based firewall:
Placed at a network boundary to protect multiple devices or network segments.

Differences:

- Packet filtering: Examines packet headers.
- Stateful: Tracks connection state.
- Circuit-level: Checks session connections.
- Proxy: Inspects application-level requests.
- NGFW: Provides advanced inspection and threat prevention.
- Host-based: Protects one device.
- Network-based: Protects a network.

Conclusion: The firewall type should be selected according to network

size, security needs and the level of traffic inspection required.

Q4. Explain Types of Access Control.

Answer:

Access Control is a security method that determines who can access a system, resource or information and what actions they can perform.

Types of access control:

1. Discretionary Access Control (DAC):

The owner of a resource decides who can access it and what permissions are granted.

Example: A file owner gives another user read permission.

2. Mandatory Access Control (MAC):

Access is controlled by a central authority using security labels and clearance levels.

Example: Military information classified as confidential or secret.

3. Role-Based Access Control (RBAC):

Permissions are assigned according to a user's job role.

Example: An administrator can manage users, while an employee can only view permitted records.

4. Attribute-Based Access Control (ABAC):

Access decisions are based on attributes such as user role, department, location, device and time.

Example: A staff member can access a company system only from an approved device.

5. Rule-Based Access Control:

Access is granted or denied according to predefined system-wide rules.

Example: A firewall permits traffic only from specified IP addresses.

Conclusion: Access control protects resources by ensuring that users receive only the permissions required for their work.

Q5. Explain Access Control models and mechanisms.

Answer:

An access control model defines the rules used to decide who can access resources. Access control mechanisms are the technical methods used to enforce those rules.

Access control models:

1. DAC: Resource owners decide permissions.
2. MAC: A central authority uses security labels and clearance levels.
3. RBAC: Permissions are assigned to roles, and users receive permissions through their roles.
4. ABAC: Decisions depend on attributes of the user, resource, action and environment.

Access control mechanisms:

- Identification: User claims an identity, such as entering a username.
- Authentication: System verifies the claimed identity, such as by password or biometric.
- Authorization: System decides what the authenticated user is allowed to do.
- Access Control Lists (ACLs): Specify which users or groups can access an object and their permissions.
- Capability lists/tokens: Provide specific rights to access resources.
- Logging and monitoring: Record access activities for review.
- Multi-factor authentication: Uses two or more different authentication factors.

Example:

In a college portal, a student logs in using a password (authentication). The RBAC model assigns the student role. Authorization allows the student to view marks but not modify them.

Conclusion: Models define access rules, while mechanisms implement and enforce those rules.

Q6. Describe Cyber Security Audit types.

Answer:

Cyber Security Audit types are different approaches used to examine an organization's security controls and practices.

1. Internal audit:

Conducted by the organization's own audit team to check internal security controls and policies.

2. External audit:

Conducted by an independent third party to provide an objective assessment.

3. Compliance audit:
Checks whether the organization follows applicable laws, regulations, contracts or standards.

4. Technical audit:
Examines technical systems such as servers, networks, firewalls, applications and databases.

5. Vulnerability assessment:
Identifies and prioritizes weaknesses in systems and networks.

6. Penetration testing:
An authorized simulated attack used to determine whether identified weaknesses can be exploited.

7. Cloud security audit:
Reviews cloud configurations, access permissions, data protection and service security.

8. Physical security audit:
Checks physical access to offices, data centres, server rooms and devices.

Conclusion: Different audit types examine different areas. Organizations may combine them to obtain a complete view of their security posture.

Q7. What is meant by Authentication? Describe the different authentication models.

Answer:
Authentication is the process of verifying the identity of a user, device or system before allowing access to a resource.

Main authentication factors:

1. Something you know:
Information known by the user.
Examples: Password, PIN and security answer.

2. Something you have:
A physical or digital item possessed by the user.
Examples: Smart card, security token or one-time password (OTP) device.

3. Something you are:
A biometric characteristic of the user.

Examples: Fingerprint, face, iris or voice.

4. Somewhere you are:
The user's location, such as an approved office network or geographic location. This is commonly used as a contextual factor.

5. Something you do:
A behavioural characteristic, such as typing rhythm or signature dynamics.

Authentication models:

- Single-factor authentication: Uses one factor, such as a password.
- Two-factor authentication (2FA): Uses two different factors, such as a password and an OTP from a token.
- Multi-factor authentication (MFA): Uses two or more independent factors.
- Biometric authentication: Verifies identity using physical or behavioural characteristics.
- Certificate-based authentication: Uses digital certificates and cryptographic keys to verify identity.

Example: A bank app may ask for a password and then verify a fingerprint. This is two-factor authentication if the factors are independent.

Conclusion: Authentication prevents unauthorized access by checking identity before access is granted.

Q8. What are the different threats in authentication? What practices should one follow for authentication?

Answer:
Authentication threats are attacks or weaknesses that allow an attacker to impersonate a legitimate user or gain unauthorized access.

Major threats:

1. Brute-force attack: Trying many password combinations until the correct one is found.
2. Dictionary attack: Trying passwords from a list of common words and passwords.
3. Phishing: Tricking users into entering credentials on fake websites.
4. Credential stuffing: Using stolen username-password pairs on other websites.

5. Keylogging: Recording keystrokes to capture passwords.
6. Shoulder surfing: Observing a person while they enter a password or PIN.
7. Man-in-the-middle attack: Intercepting communication to steal or alter authentication data.
8. SIM swapping / OTP interception: Taking control of a phone number or intercepting one-time codes.
9. Session hijacking: Taking over an authenticated session.

Best practices:

- Use long, unique passwords for every account.
- Use a password manager.
- Enable multi-factor authentication.
- Never share passwords or OTPs.
- Verify website addresses before entering credentials.
- Use HTTPS and trusted networks.
- Avoid login links in suspicious messages.
- Apply account lockout, rate limiting and monitoring.
- Keep devices and applications updated.
- Log out from shared devices and protect recovery methods.

Conclusion: Strong authentication and user awareness reduce the chance of account compromise.

Q9. Explain different types of Biometrics.

Answer:

Biometrics is the process of identifying or verifying a person using unique physical or behavioural characteristics.

Types of biometrics:

A) Physiological biometrics:

Based on physical features of the human body.

1. Fingerprint recognition: Uses patterns of ridges and valleys in a finger.
2. Face recognition: Analyzes facial features and their arrangement.
3. Iris recognition: Examines unique patterns in the coloured part of the eye.
4. Retina recognition: Uses patterns of blood vessels at the back of the eye.

5. Hand geometry: Measures the shape and dimensions of the hand.
6. Palm print recognition: Uses lines and patterns on the palm.

B) Behavioural biometrics:
Based on the way a person performs an activity.
1. Voice recognition: Analyses voice characteristics.
2. Signature recognition: Examines the style and dynamics of a signature.
3. Keystroke dynamics: Measures typing speed and rhythm.
4. Gait recognition: Identifies a person by walking pattern.

Conclusion: Biometrics provides convenient identity verification, but systems must protect biometric data and include safeguards against spoofing.

Q10. Explain advantages and limitations of Biometrics.

Answer:
Biometrics identifies or verifies people using physical or behavioural characteristics.

Advantages:
1. Convenience: Users do not need to remember passwords.
2. Uniqueness: Many biometric traits differ from person to person.
3. Difficult to share: A biometric characteristic is linked to the individual.
4. Fast verification: Modern systems can verify users quickly.
5. Better user experience: Fingerprint or face verification can simplify login.
6. Useful for accountability: Can help record who accessed a system.

Limitations:
1. Privacy concerns: Biometric information is highly personal.
2. Data theft risk: A compromised biometric template cannot be changed as easily as a password.
3. False acceptance/rejection: Systems may incorrectly accept or reject a user.
4. Spoofing: Fake fingerprints, photos or recordings may attack weak systems.
5. Cost: Accurate biometric devices and systems may be expensive.
6. Environmental effects: Lighting, noise, injury or sensor quality can affect accuracy.
7. Accessibility: Some users may not be able to provide a particular

biometric trait.

Conclusion: Biometrics offers convenient authentication, but it should be combined with secure storage, liveness detection and alternative authentication methods.

Q11. Explain Applications of Biometrics.

Answer:

Biometrics is used in many areas to identify or verify individuals based on physical or behavioural characteristics.

Applications:

1. Mobile devices: Fingerprint and face unlock protect smartphones.
2. Banking: Biometric checks may be used for customer verification and transaction security.
3. Government services: Used in identity verification and selected public-service systems.
4. Border control: Facial and fingerprint systems may assist identity checks at airports.
5. Workplace security: Controls entry to offices, laboratories and restricted areas.
6. Healthcare: Helps verify patient identity and control access to medical records.
7. Law enforcement: Fingerprints and facial comparisons may support investigations, subject to legal rules.
8. Education: May be used for attendance and identity verification.
9. Financial services: Supports customer onboarding and fraud prevention.
10. Computer access: Controls access to systems and sensitive applications.

Conclusion: Biometrics is useful wherever reliable identity verification is required. Its use should respect privacy, consent and data-protection requirements.

Q12. Describe Denial of Service Attack in detail.

Answer:

A Denial of Service (DoS) attack is a cyberattack in which an attacker attempts to make a computer, server, website or network unavailable to legitimate users by overwhelming it or exhausting its resources.

Types:

1. Volumetric attack: Sends a large amount of traffic to consume network bandwidth.
2. Protocol attack: Exploits weaknesses in network protocols or connection handling.
3. Application-layer attack: Sends excessive requests to an application, such as a web server.
4. Distributed Denial of Service (DDoS): Uses many compromised devices to attack one target at the same time.

Working:

Attacker → Large or repeated traffic → Target server/network → Resources exhausted → Genuine users cannot access service.

Effects:

- Website or service downtime.
- Financial loss and reduced productivity.
- Damage to reputation and customer trust.
- Disruption of essential services.
- Increased recovery and mitigation costs.

Prevention and mitigation:

- Use firewalls and DDoS protection services.
- Apply rate limiting and traffic filtering.
- Use load balancing and scalable infrastructure.
- Monitor traffic for unusual patterns.
- Work with internet service providers and incident-response teams.
- Maintain a response and recovery plan.

Conclusion: DoS attacks affect availability, one of the three principles of the CIA Triad. Layered network protection and continuous monitoring help reduce their impact.

Q13. Explain in detail about Ethical Hacking.

Answer:

Ethical Hacking is the authorized process of testing computers, networks or applications to identify security weaknesses before malicious attackers exploit them.

An ethical hacker works with permission, follows a defined scope and reports findings responsibly.

Phases of ethical hacking:

1. Planning and permission: Obtain written authorization and define scope and rules.
2. Reconnaissance: Collect information about the target system.
3. Scanning and enumeration: Identify active hosts, open ports, services and possible weaknesses.
4. Vulnerability analysis: Assess discovered weaknesses and their possible impact.
5. Controlled exploitation: Safely validate selected vulnerabilities within the approved scope.
6. Post-exploitation assessment: Determine the potential impact without causing unnecessary damage.
7. Reporting: Document evidence, risk levels and recommended fixes.
8. Retesting: Verify whether the organization has corrected the weaknesses.

Types:

- Black-box testing: Tester has little or no prior information.
- White-box testing: Tester has detailed information about the system.
- Grey-box testing: Tester has partial information.

Example: A company authorizes a security tester to check its website. The tester identifies an insecure login configuration, reports it and recommends corrective measures.

Conclusion: Ethical hacking improves security when it is performed legally, with permission and within a clearly defined scope.

Q14. List the advantages, limitations and applications of ethical hacking.

Answer:

Ethical hacking is an authorized security assessment that identifies weaknesses in systems and applications.

Advantages:

1. Identifies vulnerabilities before criminals exploit them.
2. Helps improve network and application security.
3. Tests the effectiveness of existing security controls.
4. Helps protect confidential data.
5. Supports security awareness and compliance efforts.

6. Reduces the likelihood and impact of cyber incidents.

Limitations:

1. It cannot guarantee that every vulnerability will be found.
2. Testing may be costly and time-consuming.
3. Results depend on tester skill and test scope.
4. Poorly controlled tests may disrupt services.
5. Systems may change after the test, creating new weaknesses.
6. Testing requires written authorization and legal boundaries.

Applications:

- Web and mobile application testing.
- Network and server security assessment.
- Cloud infrastructure security testing.
- Wireless network assessment.
- Testing security controls in banks and organizations.
- Reviewing systems before product or service launch.

Conclusion: Ethical hacking is a valuable preventive security practice, but it must be carefully planned, authorized and followed by remediation.

Q15. Explain Intrusion Detection System (IDS). Differentiate between types of IDS.

Answer:

An Intrusion Detection System (IDS) is a security tool that monitors network traffic or system activities to identify suspicious behaviour, policy violations or possible attacks. It generates alerts for administrators.

Types of IDS based on monitoring location:

1. Network-based IDS (NIDS):

Monitors traffic flowing across a network segment.

Example: Detecting suspicious traffic passing through a network gateway.

2. Host-based IDS (HIDS):

Monitors activities on an individual computer or server, such as system logs, files and processes.

Example: Detecting unauthorized changes to important server files.

Types based on detection method:

3. Signature-based IDS:

Compares activity with known attack patterns or signatures. It is effective for known threats but may miss new attacks.

4. Anomaly-based IDS:

Learns or defines normal behaviour and alerts when activity differs significantly. It may detect unknown threats but can produce false alarms.

Difference:

- NIDS: Monitors network traffic.
- HIDS: Monitors one host or device.
- Signature-based: Detects known patterns.
- Anomaly-based: Detects deviations from normal behaviour.

IDS vs IPS:

An IDS mainly detects and alerts. An Intrusion Prevention System (IPS) can also take action to block or prevent detected traffic.

Conclusion: IDS improves visibility and helps administrators respond to attacks. It is most effective when combined with firewalls, access controls and incident response.

Q16. Explain Threat Management Process.

Answer:

Threat Management is the continuous process of identifying, assessing, prioritizing and reducing threats that may harm an organization's information systems.

Steps:

1. Identify assets: List important data, devices, applications and services.
2. Identify threats: Consider malware, phishing, insiders, DoS attacks and physical threats.
3. Identify vulnerabilities: Find weaknesses that threats may exploit.
4. Assess risk: Estimate the likelihood and impact of each threat.
5. Prioritize: Rank risks according to severity and business impact.
6. Select controls: Apply safeguards such as patching, encryption, firewalls and access control.
7. Respond to incidents: Detect, contain, remove and recover from security incidents.
8. Monitor continuously: Review logs, alerts and threat intelligence.

9. Review and improve: Update controls and plans as systems and threats change.

Flow:

Identify Assets □ Identify Threats □ Find Vulnerabilities □ Assess Risk □ Apply Controls □ Monitor □ Review

Conclusion: Threat management is an ongoing activity that reduces the likelihood and impact of cyber incidents.

Q17. Explain relationship between Security Policy and Threat Management.

Answer:

A Security Policy is a formal set of rules that defines how an organization protects its information and technology resources. Threat Management is the process of identifying, assessing and reducing possible security threats.

Relationship:

1. Policy provides direction: It defines security objectives, responsibilities and acceptable practices.
2. Threat management identifies risks: It finds threats and vulnerabilities that may affect organizational assets.
3. Policy guides controls: The policy specifies required safeguards such as passwords, access control, backups and encryption.
4. Threat assessment supports policy updates: New threats may require changes in policies and procedures.
5. Incident response: The policy defines reporting and response responsibilities, while threat management helps coordinate the response.
6. Continuous improvement: Audit results and incident lessons help improve both the policy and threat-management process.

Example:

If threat management identifies phishing as a major risk, the organization may update its security policy to require awareness training, email filtering and multi-factor authentication.

Conclusion: Security policy defines what must be protected and the rules to follow, while threat management identifies and handles the risks. Both work together to improve cybersecurity.

Q18. Explain Security Policy and its objectives.

Answer:

A Security Policy is a formal document that defines rules, responsibilities and procedures for protecting an organization's information, systems and networks.

Objectives:

1. Confidentiality: Ensure information is available only to authorized people.
2. Integrity: Protect information from unauthorized modification or destruction.
3. Availability: Ensure systems and data are available when required.
4. Access control: Define who can access resources and what actions they can perform.
5. Risk reduction: Reduce the possibility and impact of security incidents.
6. Legal compliance: Help the organization follow applicable laws and standards.
7. Accountability: Assign security responsibilities and maintain activity records.
8. Incident handling: Define how security incidents should be reported and managed.
9. Awareness: Educate employees about secure behaviour.
10. Business continuity: Support backup, recovery and continuity planning.

Conclusion: A security policy creates a common framework for protecting digital assets and ensuring that everyone follows consistent security practices.

Q19. Explain Types of Security Policies and their key components.

Answer:

A Security Policy defines how an organization protects its information and technology resources.

Types of security policies:

1. Organizational / Enterprise Information Security Policy:
A high-level policy that defines the overall security direction, objectives and responsibilities of the organization.

2. Issue-Specific Security Policy:
Deals with a particular topic such as email usage, internet access, password management, remote access or social media use.

3. System-Specific Security Policy:
Defines security requirements for a particular system, application, server, database or network.

Key components:

- Purpose: Explains why the policy is required.
- Scope: Identifies users, systems and information covered.
- Roles and responsibilities: Defines duties of management, IT teams and users.
- Access control: Defines permissions and authentication requirements.
- Acceptable use: Explains permitted and prohibited use of resources.
- Data protection: Covers classification, storage, sharing and disposal of information.
- Incident reporting: Explains how to report and respond to security incidents.
- Compliance and enforcement: Defines monitoring and consequences of violations.
- Training and awareness: Describes user education requirements.
- Review and updates: Specifies how often the policy is reviewed.

Conclusion: Different policies address organization-wide, topic-specific and system-specific requirements. Together, they provide a structured approach to information security.